

ENTERPRISE SECURITY ASSESSMENT LAB

AWS CLI AUTHENTICATION AND IDENTITY VERIFICATION

Professional methodology report for validating CloudGoat / AWS lab access before enumeration

Module	Cloud Security Assessment
Document Type	Individual Methodology Report
Phase	Phase 1
Evidence Source	01-aws-cli-authenticated-get-caller-identity.png
Publication Type	GitHub Portfolio - Redacted Lab Version
Prepared For	04-cloud-security/README.md documentation set
File Name	01-aws-cli-authentication-and-identity-verification-methodology-report.pdf

1. Executive Purpose

This section documents the starting point of the cloud security assessment. Before testing IAM permissions, S3 access, EC2 metadata, or automated audit output, the tester must prove which AWS identity is being used. This prevents accidental testing from the wrong account, wrong profile, or wrong region and makes the evidence repeatable for GitHub review.

2. Scope and Evidence Mapping

Testing objective	Confirm that the AWS CLI is authenticated with the dedicated CloudGoat/lab profile before performing enumeration.
Cloud platform	Amazon Web Services (AWS)
Lab context	CloudGoat / authorized vulnerable cloud lab environment
Primary tools	AWS CLI, STS, Kali Linux terminal
Evidence file(s)	01-aws-cli-authenticated-get-caller-identity.png
Result type	AWS CLI authentication confirmed using lab profile

3. Embedded Evidence Screenshot(s)

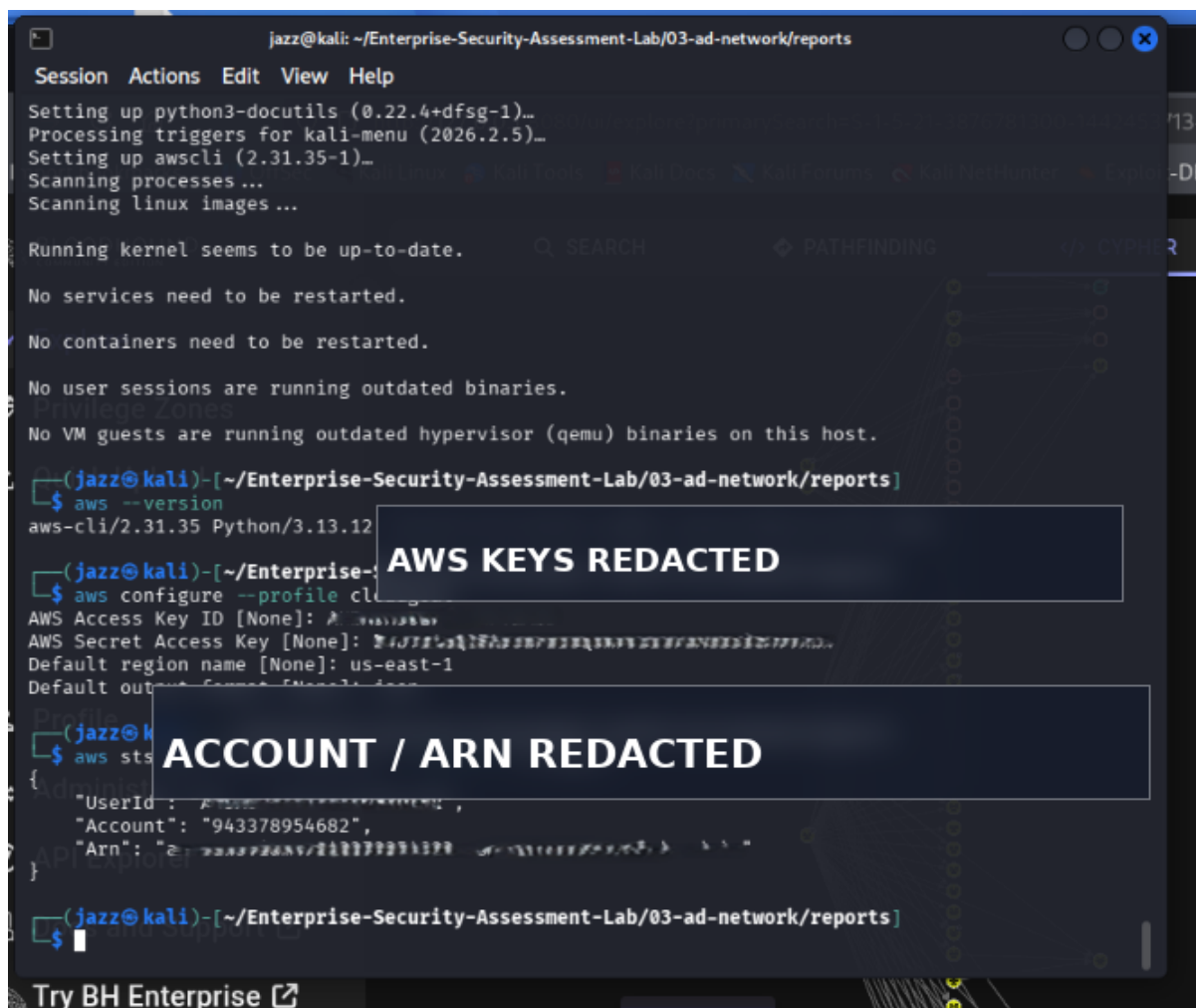


Figure 1 - AWS CLI profile configuration and get-caller-identity output with account data redacted.

4. Methodology and Execution Workflow

The workflow begins by defining the AWS CLI profile and region used for the lab. The identity is then confirmed through AWS STS. The output should show UserId, Account, and Arn, but all account identifiers must be redacted before publication.

Command / workflow used

```
PROFILE=cloudgoat
REGION=us-east-1

aws sts get-caller-identity --profile $PROFILE --region $REGION
```

Execution notes

- Use a dedicated lab profile rather than root credentials.
- Confirm the configured region before running enumeration tools.
- Do not publish the Account field or full ARN in GitHub screenshots.
- Treat this as a pre-check before any cloud testing begins.

5. Sanitized Tool Output Style

The following output example is sanitized. It documents the expected evidence style without exposing AWS account IDs, ARN values, AccessKeyId values, SecretAccessKey values, session tokens, private bucket names, or billing details.

```
{
  "UserId": "<REDACTED_USER_ID>",
  "Account": "<REDACTED_ACCOUNT_ID>",
  "Arn": "arn:aws:iam::<REDACTED_ACCOUNT_ID>:user/<REDACTED_USER>"
}
```

6. Professional Interpretation

The evidence proves that the AWS CLI was configured and authenticated with the lab profile. This establishes the identity used for later IAM enumeration, Pacu analysis, S3 testing, ScoutSuite auditing, IMDS validation, cleanup, and billing verification.

7. Risk Analysis

Risk Area	Explanation
Wrong profile risk	Using the wrong CLI profile can accidentally enumerate or modify non-lab resources.
Credential exposure risk	Screenshots of get-caller-identity can reveal account IDs and ARNs that should not be public.
Operational control value	Identity verification improves repeatability and shows responsible cloud testing discipline.

8. Defensive Recommendations

- Use separate AWS accounts or profiles for labs and personal/production work.
- Do not use root credentials for lab testing.
- Enable MFA and budget alerts on the account.
- Rotate keys after lab work if any values may have been exposed.

- Store credentials outside the Git repository and never commit .aws/credentials.

9. GitHub Redaction and Publication Guidance

Before publishing this document or the underlying screenshot evidence, verify that the following values are removed, blurred, or replaced with placeholders. This is especially important because cloud evidence can contain values that are valid beyond the lab session if not rotated or destroyed.

Sensitive value	Required handling
AWS Account ID	Blur or replace with <REDACTED_ACCOUNT_ID>.
ARN values	Redact account number and private role/user names where needed.
AccessKeyId / SecretAccessKey	Must never be visible. Rotate immediately if exposed.
SessionToken	Must be fully redacted because temporary credentials can still be abused during validity period.
Bucket names / resource names	Redact if they identify private infrastructure or are still active.

10. Evidence Quality Checklist

- The screenshot is readable and aligned within the page margins.
- The evidence filename matches the GitHub link exactly.
- The command/output supports the stated result type.
- No AWS credentials, session tokens, account numbers, or private resource identifiers are visible.
- The report explains both the offensive testing value and the defensive remediation value.